

SOC-звіт: плейбук реагування на інцидент

Report ID	6
Created At	2026-06-05 03:42:45
Severity	High
Severity Confidence	High

1. Початковий сценарій інциденту

EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл із `hxxp[:]//185[.]225[.]73[.]244[:]:8000/update[.]ps1` та зберегти його у `C:\Users\Public\update.ps1`. Після виконання скрипта робоча станція почала встановлювати повторні зовнішні з'єднання з `api-sync-gateway[.]top`. Така активність може вказувати на завантаження шкідливого payload та можливий Command and Control канал.

2. AI-оцінка інциденту

Severity: High | **Confidence:** High

Обґрунтування: Запуск PowerShell з несанкціонованим завантаженням скрипта з відомого шкідливого IP-адреси та подальше встановлення повторних зовнішніх з'єднань з іншим доменом чітко вказує на компрометацію робочої станції та встановлення каналу Command and Control. Це становить значний ризик для організації, особливо враховуючи, що робоча станція належить HR-відділу і може містити конфіденційні дані. Загроза активна та підтверджена даними розвідки загроз.

Контекст IOC: Контекст Threat Intelligence був доступний і значно вплинув на оцінку серйозності. IP-адреса 185.225.73.244, з якої був завантажений скрипт, була ідентифікована як шкідлива з високим рівнем впевненості кількома джерелами TI (VirusTotal, AlienVault OTX). Це підтверджує, що початкове завантаження відбулося зі скомпрометованого або ворожого джерела. Хоча URL-адреса скрипта та домен `api-sync-gateway.top` наразі не позначені як шкідливі у джерелах TI, поведінка робочої станції (повторні зовнішні з'єднання після виконання скрипта) разом з інформацією про шкідливий IP-адрес робить інцидент високоризиковим, вказуючи на встановлений канал управління та контролю.

3. Виявлені IOC та результати Threat Intelligence

IOC	Type	Verdict	Confidence	Sources	Summary
<code>http://185.225.73.244:8000/update.ps1</code>	URL	Clean or Not Listed	Medium	0/4	0 із 4 перевірених джерел позначили цей IOC як шкідливий. Фінальний висновок агента: Clean or Not Listed; впевненість: Medium.
185.225.73.244	IP Address	Malicious	High	2/4	2 із 4 перевірених джерел позначили цей IOC як підозрілий або шкідливий. Фінальний висновок агента: Malicious; впевненість: High.
<code>api-sync-gateway.top</code>	Domain	Clean or Not Listed	Medium	0/3	0 із 3 перевірених джерел позначили цей IOC як шкідливий. Фінальний висновок агента: Clean or Not Listed; впевненість: Medium.

4. AI-рекомендації MITRE ATT&CK;

ID	Technique	Tactic	Confidence	Evidence
T1566	Phishing	Initial Access	Medium	Сценарій описує запуск шкідливого скрипта PowerShell на робочій станції HR-відділу, що призвело до компрометації.
T1204	User Execution	Execution	High	EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл та зберегти його. Після виконання скрипта робоча станція почала встановлювати повторні зовнішні з'єднання.

ID	Technique	Tactic	Confidence	Evidence
T1059	Command and Scripting Interpreter	Execution	High	EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл...
T1059.001	PowerShell	Execution	High	EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл...
T1105	Ingress Tool Transfer	Command and Control	High	Команда намагалася завантажити файл із <code>hxxp[.]/185[.]225[.]73[.]244[.]8000/update[.]ps1</code> та зберегти його у <code>C:\Users\Public\update.ps1</code> .
T1071	Application Layer Protocol	Command and Control	Medium	Команда намагалася завантажити файл із <code>hxxp[.]/185[.]225[.]73[.]244[.]8000/update[.]ps1</code> та робоча станція почала встановлювати повторні зовнішні з'єднання з <code>api-sync-gateway[.]top</code> .

5. Згенерований плейбук реагування на інцидент

1. Ідентифікація та Оцінка Масштабу

Тип атаки: Цей інцидент являє собою комбінацію технік початкового доступу, виконання та управління та контролю. Ймовірно, зловмисники використали соціальну інженерію (можливо, фішинг) для отримання початкового виконання шкідливого скрипта PowerShell, що призвело до встановлення каналу Command and Control (C2) на скомпрометованій робочій станції. Це свідчить про активну компрометацію системи.

- Журнали/Інструменти для перевірки:**

EDR (Endpoint Detection and Response): Повні журнали процесів, мережних з'єднань, модифікацій файлової системи на HR-021 та інших підозрілих хостах.

Журнали брандмауера: Спроби з'єднань до 185.225.73.244 та `api-sync-gateway.top` з інших внутрішніх хостів.

Журнали проксі-сервера: HTTP/HTTPS запити на 185.225.73.244:8000/update.ps1 та `api-sync-gateway.top`.

Журнали DNS: Запити на розрешення `api-sync-gateway.top`.

Журнали SIEM: Кореляція подій для виявлення подібної активності в інших частинах мережі.

Журнали Active Directory: Зміни у облікових записах користувачів, які могли бути скомпрометовані.

Антивірусні (AV) журнали: Результати сканування на HR-021.

- Оцінка серйозності:**

Level: High

Confidence: High

Rationale: Запуск PowerShell з несанкціонованим завантаженням скрипта з відомого шкідливого IP-адреси та подальше встановлення повторних зовнішніх з'єднань з іншим доменом чітко вказує на компрометацію робочої станції та встановлення каналу Command and Control. Це становить значний ризик для організації, особливо враховуючи, що робоча станція належить HR-відділу і може містити конфіденційні дані. Загроза активна та підтверджена даними розвідки загроз.

IOC Context Note: Контекст Threat Intelligence був доступний і значно вплинув на оцінку серйозності. IP-адреса 185.225.73.244, з якої був завантажений скрипт, була ідентифікована як шкідлива з високим рівнем впевненості кількома джерелами TI (VirusTotal, AlienVault OTX). Це підтверджує, що початкове завантаження відбулося зі скомпрометованого або ворожого джерела. Хоча URL-адреса скрипта та домен `api-sync-gateway.top` наразі не позначені як шкідливі у джерелах TI, поведінка робочої станції (повторні зовнішні з'єднання після виконання скрипта) разом з інформацією про шкідливий IP-адрес робить інцидент високоризиковим, вказуючи на встановлений канал управління та контролю.

- Відповідні IOCs (індикатори компрометації):**

IP-адреса: 185.225.73.244 (Verdict: Malicious, Confidence: High)

URL: `hxxp[.]/185[.]225[.]73[.]244[.]8000/update[.]ps1` (Verdict: Clean or Not Listed, Confidence: Medium)

Шлях до файлу: `C:\Users\Public\update.ps1`

Домен: `api-sync-gateway.top` (Verdict: Clean or Not Listed, Confidence: Medium)

- Можливі MITRE ATT&CK техніки:**

T1566 Phishing (Initial Access)

Confidence: Medium

Evidence: Сценарій описує запуск шкідливого скрипта PowerShell на робочій станції HR-відділу, що призвело до компрометації.

Reasoning: Хоча прямих доказів фішингу немає, такий метод початкового доступу, що призводить до завантаження та виконання шкідливого скрипта, часто починається із фішингових електронних листів, шкідливих посилань або документів.

T1204 User Execution (Execution)

Confidence: High

Evidence: EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл та зберегти його. Після виконання скрипта робоча станція почала встановлювати повторні зовнішні з'єднання.

Reasoning: Виконання скрипта PowerShell, особливо з невідомого джерела та його збереження у файловій системі, зазвичай вимагає певної дії з боку користувача для ініціації, що призводить до виконання шкідливого коду.

T1059 Command and Scripting Interpreter (Execution)

Confidence: High

Evidence: EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл...

Reasoning: Зловмисники використовують інтерпретатори командних рядків, такі як PowerShell, для виконання команд і скриптів на цільовій системі для виконання шкідливих дій.

T1059.001 PowerShell (Execution)

Confidence: High

Evidence: EDR зафіксував запуск PowerShell на робочій станції HR-021. Команда намагалася завантажити файл...

Reasoning: PowerShell є потужним інструментом, який часто використовується зловмисниками для виконання шкідливих команд, завантаження додаткового корисного навантаження, виконання скриптів 'без файлів' та підтримки присутності.

T1105 Ingress Tool Transfer (Command and Control)

Confidence: High

Evidence: Команда намагалася завантажити файл із `hxxp[:]//185[.]225[.]73[.]244[:/]8000/update[.]ps1` та зберегти його у `C:\Users\Public\update.ps1`.

Reasoning: Передача інструментів або корисного навантаження (в даному випадку, скрипта PowerShell) на скомпрометовану систему з зовнішнього джерела є типовим кроком після отримання початкового доступу для подальшого розвитку атаки.

T1071 Application Layer Protocol (Command and Control)

Confidence: Medium

Evidence: Команда намагалася завантажити файл із `hxxp[:]//185[.]225[.]73[.]244[:/]8000/update[.]ps1...` та робоча станція почала встановлювати повторні зовнішні з'єднання з `api-sync-gateway[.]top`.

Reasoning: Зловмисники часто використовують поширені протоколи прикладного рівня, такі як HTTP/HTTPS, для встановлення зв'язку Command and Control (C2), оскільки це допомагає їм залишатися непоміченими серед звичайного мережевого трафіку.

2. Стимування

- **Короткострокові дії:**

Ізолюйте робочу станцію: негайно ізолюйте робочу станцію HR-021 від корпоративної мережі, перевіривши її в режим "мережевої ізоляції" через EDR або фізично відключивши від мережі.

Блокуйте IOCs: Додайте 185.225.73.244 та `api-sync-gateway.top` до "чорних списків" на мережевих брандмауерах, проксі-серверах та DNS-фільтрах, щоб запобігти подальшим з'єднанням або доступу з інших систем.

Вимкніть обліковий запис: Якщо можливо, тимчасово вимкніть або принаймні змініть пароль облікового запису користувача, який був активний на HR-021 під час інциденту.

Зробіть образ/копію: Зробіть повний образ диска або логічну копію відповідних файлів з HR-021 для подальшого криміналістичного аналізу.

- **Довгострокові дії:**

Перегляньте політики сегментації мережі: Оцініть та, за необхідності, посилюйте сегментацію мережі, особливо між відділами (наприклад, HR) та критичними активами, щоб мінімізувати горизонтальне переміщення.

Посиліть політики виконання скриптів: Впровадьте або посилюйте політики обмеження виконання скриптів (наприклад, AppLocker, Device Guard, PowerShell Constrained Language Mode) на всіх кінцевих точках.

Посиліть моніторинг C2: Впровадьте посилений моніторинг для виявлення аномальних вихідних з'єднань, особливо на нестандартні порти або до невідомих доменів, щоб виявляти потенційні канали управління та контролю.

3. Видалення

Видалення шкідливих файлів: Видаліть файл C:\Users\Public\update.ps1 та будь-які інші файли, створені або змінені шкідливим скриптом.

- **Перевірка на персистентність:**

Перевірте автозапуск (Startup folders, Registry Run keys).

Перевірте заплановані завдання (Task Scheduler).

Перевірте сервіси Windows.

Перевірте WMI-події та скрипти.

Перевірте завантажені модулі PowerShell.

Антивірусне сканування: Виконайте повне сканування робочої станції HR-021 за допомогою актуального антивірусного програмного забезпечення/EDR в режимі глибокого сканування.

Перевірка інших систем: Проведіть пошук (threat hunt) по всій мережі на наявність інших систем, які могли бути скомпрометовані аналогічним чином, використовуючи зібрані IOCs.

Очищення кешів та тимчасових файлів: Очистіть кеші веб-браузерів, тимчасові файли та інші потенційні місця зберігання шкідливих артефактів.

4. Відновлення

- **Відновлення системи:**

Найкращий варіант: Перевстановити операційну систему HR-021 з нуля, використовуючи затверджений корпоративний образ.

Альтернатива: Відновити систему з чистої резервної копії, яка була зроблена до моменту компрометації.

Зміна паролів: Виконайте примусову зміну паролів для всіх облікових записів, які могли бути скомпрометовані або були активні на HR-021 під час інциденту. Розгляньте можливість скидання всіх паролів для HR-відділу.

Повторна інтеграція в мережу: Після підтвердження чистоти системи, обережно повторно інтегруйте HR-021 в мережу, переконавшись, що застосовані всі відповідні політики безпеки та патчі.

Перевірка функціональності: Підтвердіть, що всі необхідні програми та сервіси на HR-021 функціонують належним чином.

Посилений моніторинг: Забезпечте посилений моніторинг HR-021 та інших критичних систем протягом наступних 24-48 годин для виявлення будь-яких ознак повторної компрометації.

Комунікація: Проінформуйте команду HR про інцидент, запевніть їх у вжитих заходах і, за необхідності, проведіть короткий брифінг з безпеки.

5. Висновки

Підсумок аналізу першопричин: Інцидент розпочався з успішного виконання PowerShell скрипта на робочій станції HR-021, який було завантажено з відомого шкідливого IP-адреси. Ймовірно, це сталося внаслідок дії користувача, можливо, через фішинг. Після виконання скрипт встановив канал управління та контролю з доменом api-sync-gateway.top, що дозволило зловмисникам підтримувати доступ до скомпрометованої системи. Першопричиною є недостатні засоби запобігання початковому доступу та/або недостатня обізнаність користувачів.

- **Рекомендації:**

Посилення фільтрації електронної пошти: Впровадити або посилити рішення для фільтрації електронної пошти, які ефективно виявляють та блокують фішингові та шкідливі листи.

Навчання співробітників з кібербезпеки: Провести обов'язкове та регулярне навчання з питань кібербезпеки для всіх співробітників, особливо для HR-відділу, зосереджуючись на розпізнаванні фішингу, шкідливих посилань та вкладень.

Впровадження/посилення політик виконання скриптів: Застосувати строгі політики AppLocker або Device Guard для обмеження виконання несанкціонованих скриптів PowerShell та інших виконуваних файлів.

Посилення моніторингу EDR та мережі: Переглянути та оптимізувати правила виявлення EDR та SIEM для більш ефективного виявлення аномальної активності PowerShell, завантажень з невідомих джерел та C2-з'єднань.

Вдосконалення інтеграції Threat Intelligence: Забезпечити кращу інтеграцію та автоматизацію використання даних Threat Intelligence для швидкого блокування відомих шкідливих IOCs.

Оновлення плану реагування на інциденти: Включити уроки, отримані з цього інциденту, до існуючого плану реагування на інциденти, зокрема, щодо швидкої ізоляції систем та подальших кроків з видалення та відновлення.

Додаток: вихідний код Mermaid

```
graph TD
    START[Початок]:::START_END
    START --> A{Виявлено активність EDR?}:::DECISION
    A -->|Так| B[Аналіз інциденту]:::ACTION
    B --> C{Severity: High?}:::DECISION
    C -->|Так| D[Ізолювати HR-021]:::ACTION
    D --> E[Блокувати IOCs]:::ACTION
    E --> F[Вимкнути обліковий запис]:::ACTION
    F --> G[Видалити шкідливий скрипт]:::ACTION
    G --> H[Перевірити персистентність]:::ACTION
    H --> I[Просканувати антивірусом]:::ACTION
    I --> J[Перевірити інші системи]:::ACTION
    J --> K[Відновити HR-021]:::ACTION
    K --> L[Змінити паролі]:::ACTION
    L --> M[Повторна інтеграція в мережу]:::ACTION
    M --> N[Моніторинг 24 or 48 годин]:::ACTION
    N --> O[Аналіз першопричин]:::ACTION
    O --> P[Рекомендації]:::ACTION
    P --> END[Кінець]:::START_END

classDef DECISION fill:#330000,stroke:#ff0000,stroke-width:2px,color:#fff;
classDef ACTION fill:#001a00,stroke:#00ff00,stroke-width:2px,color:#fff;
classDef START_END fill:#1a1a1a,stroke:#fff,stroke-width:2px,color:#fff;
```